

TP 1 — Fondamentaux de l'administration sécurisée

Module : Administration sécurisée Linux / Windows

Séquence : Séquence 1 — Fondamentaux de l'administration sécurisée

Durée indicative : 45 minutes

Niveau : Élèves ingénieurs

Compétences visées : C10 — C14

1. Contexte

Vous venez d'intégrer l'équipe infrastructure d'une entreprise.

Deux nouveaux serveurs doivent être contrôlés avant leur mise en production :

- un serveur Linux ;
- un serveur Windows Server.

Ces serveurs ont été installés par une autre équipe. Votre responsable vous demande d'effectuer un **premier audit de sécurité des comptes et privilèges**.

Votre objectif n'est pas encore de réaliser un hardening complet, mais de déterminer :

- quels utilisateurs existent ;
 - quels comptes disposent de privilèges élevés ;
 - comment sont organisés les groupes ;
 - quelles politiques d'authentification sont appliquées ;
 - si certains comptes présentent un risque ;
 - quelles premières recommandations peuvent être formulées.
-

2. Objectifs du TP

À la fin du TP, vous devez être capable de :

- identifier les comptes présents sur un système ;
 - distinguer comptes humains et comptes techniques ;
 - analyser les groupes et privilèges ;
 - identifier les comptes administrateurs ;
 - contrôler quelques paramètres liés aux mots de passe ;
 - appliquer le principe du moindre privilège ;
 - comparer la gestion des comptes sous Linux et Windows ;
 - produire une courte synthèse d'audit.
-

3. Environnement

Machine Linux

Une VM utilisant par exemple :

- Debian ;
- Ubuntu Server ;
- Red Hat Enterprise Linux ;
- Rocky Linux.

Vous devez disposer d'un compte ayant accès à sudo.

Machine Windows

Une VM Windows Server 2022 ou Windows Server 2025.

Le serveur utilisé pour ce TP est un **serveur membre ou autonome**, et non un contrôleur de domaine Active Directory.

Vous disposez d'un compte administrateur.

4. Partie A — Audit d'un serveur Linux

Mission A1 — Identifier votre utilisateur

Connectez-vous au serveur Linux.

Exécutez :

```
whoami
```

Puis :

```
id
```

Questions

1. Quel est le nom de votre utilisateur ?
 2. Quel est son UID ?
 3. Quel est son groupe principal ?
 4. À quels groupes appartient-il ?
 5. Votre utilisateur possède-t-il des privilèges particuliers ?
-

Mission A2 — Identifier les comptes présents sur le serveur

Affichez le contenu du fichier :

```
cat /etc/passwd
```

Puis utilisez :

```
getent passwd
```

Observez la structure d'une ligne :

```
utilisateur:x:UID:GID:description:home:shell
```

Exemple :

```
alice:x:1001:1001:Alice Martin:/home/alice:/bin/bash
```

Travail demandé

Identifiez au minimum :

- le compte root ;
- deux comptes utilisateurs ;
- trois comptes techniques ou systèmes.

Complétez le tableau suivant :

Compte UID Type Shell Répertoire HOME

root

Question

Pourquoi un serveur possède-t-il autant de comptes qui ne correspondent pas à des utilisateurs humains ?

5. Identifier les comptes privilégiés

Sous Linux, le compte ayant l'UID 0 possède les privilèges root.

Exécutez :

```
awk -F: '$3 == 0 {print $1}' /etc/passwd
```

Questions

1. Combien de comptes ont l'UID 0 ?
2. Quelle situation serait considérée comme anormale ?
3. Pourquoi faut-il limiter le nombre de comptes disposant de privilèges administrateur ?

6. Analyser les groupes

Affichez les groupes :

```
getent group
```

Puis vérifiez la présence du groupe donnant généralement accès à sudo.

Sur Debian/Ubuntu :

```
getent group sudo
```

Sur certaines distributions Red Hat :

```
getent group wheel
```

Travail demandé

Identifiez les utilisateurs disposant potentiellement de privilèges administrateur.

Complétez :

Utilisateur Groupe privilégié Accès administrateur potentiel

7. Vérifier les droits sudo

Exécutez :

```
sudo -l
```

Observez les commandes que votre utilisateur est autorisé à exécuter.

Questions

1. Votre utilisateur peut-il exécuter toutes les commandes ?
2. Doit-il saisir un mot de passe ?
3. Quel risque représente une configuration du type :

ALL=(ALL) NOPASSWD: ALL

4. Quelle configuration respecte davantage le principe du moindre privilège ?
-

8. Examiner la politique de mot de passe Linux

Pour votre utilisateur :

```
chage -l $(whoami)
```

Si les permissions le permettent, examinez également un autre utilisateur :

```
sudo chage -l nom_utilisateur
```

Vous pouvez aussi utiliser :

```
passwd -S nom_utilisateur
```

Relevez :

- date du dernier changement de mot de passe ;
- durée minimale ;
- durée maximale ;

- délai d'avertissement ;
- éventuelle expiration du compte.

Questions

1. Le mot de passe expire-t-il ?
2. Existe-t-il une durée maximale ?
3. Un compte sans politique d'expiration est-il nécessairement dangereux ?
4. Pourquoi les comptes techniques doivent-ils être traités différemment des comptes humains ?

9. Créer un utilisateur de test

Créez un nouvel utilisateur nommé :

`tpuser`

Selon la distribution :

`sudo adduser tpuser`

ou :

`sudo useradd -m tpuser`

Vérifiez sa création :

`id tpuser`

Puis :

`getent passwd tpuser`

Travail demandé

Ne donnez **aucun privilège administrateur** à cet utilisateur.

Expliquez en une phrase pourquoi il ne faut pas placer systématiquement les nouveaux utilisateurs dans le groupe `sudo` ou `wheel`.

10. Vérifier les connexions au serveur

Exécutez :

`who`

Puis :

`last`

Et :

`lastlog`

Questions

1. Quels utilisateurs se sont récemment connectés ?
 2. Pouvez-vous identifier des comptes n'ayant jamais été utilisés ?
 3. Pourquoi les comptes inutilisés constituent-ils un risque de sécurité ?
-

11. Partie B — Audit d'un serveur Windows

Ouvrez PowerShell **en tant qu'administrateur**.

Commencez par identifier votre utilisateur :

```
whoami
```

Puis :

```
whoami /groups
```

Questions

1. Quel utilisateur est connecté ?
 2. Quels groupes apparaissent ?
 3. Votre compte appartient-il au groupe Administrateurs ?
-

12. Identifier les comptes locaux Windows

Exécutez :

```
Get-LocalUser
```

Travail demandé

Identifiez :

- le compte Administrator ;
- le compte Guest ;
- les comptes utilisateurs ;
- les comptes éventuellement désactivés.

Complétez :

Compte	Activé	Type supposé	Observation
Administrator			
Guest			

Questions

1. Le compte Guest est-il activé ?

2. Quels comptes semblent inutilisés ?
 3. Pourquoi faut-il éviter de conserver des comptes inutiles ?
-

13. Identifier les administrateurs locaux

Exécutez :

```
Get-LocalGroupMember -Group "Administrators"
```

Selon la langue du système, le groupe peut être nommé :

Administrateurs

Travail demandé

Listez les comptes disposant de privilèges administrateur.

Questions

1. Combien d'utilisateurs possèdent des droits administrateur ?
 2. Tous ont-ils réellement besoin de ces privilèges ?
 3. Quelle règle de sécurité doit être appliquée ?
-

14. Examiner les groupes locaux

Exécutez :

```
Get-LocalGroup
```

Choisissez trois groupes et examinez leurs membres :

```
Get-LocalGroupMember -Group "NomDuGroupe"
```

Exemple de groupes intéressants

- Administrators ;
- Remote Desktop Users ;
- Users.

Question

Quel est l'intérêt d'attribuer les droits à des **groupes** plutôt que directement à chaque utilisateur ?

15. Créer un utilisateur standard Windows

Créez un utilisateur :

```
$password = Read-Host -AsSecureString
```

Puis :

```
New-LocalUser `
-Name "tpuser" `
-Password $password `
-FullName "TP User"
```

Ajoutez-le uniquement au groupe standard des utilisateurs si nécessaire.

Vérifiez :

```
Get-LocalUser -Name "tpuser"
```

Consigne

tpuser ne doit **pas** être membre du groupe Administrators.

Question

Pourquoi un administrateur système devrait-il disposer :

- d'un compte utilisateur standard ;
- et d'un compte administratif séparé ?

16. Examiner la politique de mot de passe Windows

Exécutez :

```
net accounts
```

Identifiez notamment :

- durée de vie maximale du mot de passe ;
- durée minimale ;
- longueur minimale ;
- historique des mots de passe ;
- paramètres de verrouillage.

Complétez :

Paramètre	Valeur observée
Longueur minimale	
Durée maximale	
Durée minimale	
Historique	

Paramètre	Valeur observée
Seuil de verrouillage	

Question

Identifiez deux paramètres qui pourraient être renforcés.

17. Linux vs Windows

À partir de vos observations, complétez le tableau.

Fonction	Linux	Windows
Compte administrateur principal		
Base locale des utilisateurs		
Gestion des groupes		
Élévation de privilèges		
Gestion des mots de passe		
Audit des connexions		

18. Cas d'analyse

Vous réalisez un audit et découvrez la situation suivante :

Serveur Linux

- root
- admin
- dev01
- dev02
- backup
- webapp
- admin, dev01 et dev02 appartiennent au groupe sudo.

Serveur Windows

Les comptes suivants appartiennent au groupe Administrators :

- Administrator
- admin-it
- jdupont
- service_backup
- stagiaire

Travail demandé

Pour chaque compte, classez la situation :

- acceptable ;
- à vérifier ;
- potentiellement dangereuse.

Vous devez justifier vos réponses.

19. Synthèse d'audit

Votre responsable vous demande une synthèse très courte.

Rédigez **cinq observations maximum**.

Exemple de structure :

Observation :

Plusieurs comptes disposent de privilèges administrateur.

Risque :

Compromission totale du serveur si l'un de ces comptes est compromis.

Recommandation :

Réduire le nombre d'utilisateurs administrateurs et appliquer le principe du moindre privilège.

Votre rapport doit contenir au moins :

1. une observation concernant les comptes ;
 2. une observation concernant les privilèges ;
 3. une observation concernant les mots de passe ;
 4. une recommandation Linux ;
 5. une recommandation Windows.
-

20. Question de réflexion

Un administrateur vous dit :

« Je suis administrateur système, donc mon compte quotidien doit être administrateur partout. »

Êtes-vous d'accord ?

Expliquez votre réponse en utilisant les notions suivantes :

- moindre privilège ;
 - séparation des comptes ;
 - traçabilité ;
 - réduction de la surface d'attaque.
-

21. Livrable attendu

À la fin du TP, remettez un document contenant :

Linux

- liste des comptes importants ;
- comptes disposant de privilèges administrateur ;
- résultat de l'analyse de la politique de mot de passe ;
- utilisateurs récemment connectés.

Windows

- liste des comptes locaux ;
- membres du groupe Administrators ;
- politique de mot de passe ;
- comptes désactivés ou inutilisés identifiés.

Conclusion

Présentez **cinq recommandations prioritaires** pour améliorer la sécurité des deux serveurs.

22. Critères de réussite

Le TP est considéré comme réussi si l'étudiant est capable de :

- identifier les comptes et groupes ;
 - déterminer quels comptes disposent de privilèges élevés ;
 - distinguer utilisateur standard, administrateur et compte technique ;
 - vérifier les principales politiques d'authentification ;
 - utiliser les outils Linux et PowerShell adaptés ;
 - identifier une situation présentant un risque ;
 - proposer des mesures conformes au principe du moindre privilège.
-

23. À retenir

Un système sécurisé ne commence pas par un outil de cybersécurité complexe.

Il commence par une bonne maîtrise de :

Qui peut se connecter ?

À quoi cette personne a-t-elle accès ?

Quels privilèges possède-t-elle ?

Ces privilèges sont-ils réellement nécessaires ?

La première règle de l'administration sécurisée est donc :

Donner uniquement les droits nécessaires, uniquement aux personnes qui en ont besoin et uniquement pendant la durée nécessaire.